GraphRisk README — proposed changes

For review before pushing to GitHub. Each section is shown as it will appear; everything else in the README stays as it is.

New 1. Where It Fits

A new section after "The Core Insight". Framed as working alongside existing tools — no vendor names or comparisons.

> GraphRisk isn't meant to replace the security and compliance tools an organisation already uses. It sits on top of them and connects what they report into one picture of risk.
>
> - **Monitoring and scanning tools** (SIEM/XDR, endpoint protection, vulnerability scanners, identity providers) report what's happening on each device and account. GraphRisk pulls those findings in through connectors and links them to the organisation's risks, controls and assets.
> - **Compliance programmes** track whether each control is in place. GraphRisk adds what a control's failure would expose, and which obligations — including Kenyan regulation — that touches.
> - **Risk registers** list risks. GraphRisk ties each one to the assets it affects and the specific CVEs behind it, so the register reflects what the tools are actually finding.
>
> It's built with organisations in Kenya and East Africa in mind: those that need to meet the Data Protection Act and sector cybersecurity rules, may already run open-source tooling such as Wazuh, and want one place to see how technical findings translate into risk and regulatory exposure.

Updated 2. Try It → In the browser

The Blast Radius bullet now mentions the Root cause shown under each exposed risk and asset.

> - **Blast Radius** — pick a control from the dropdown (e.g. *Multi-Factor Authentication*). **List** view shows the full cascade, with a **Root cause** under each exposed risk and asset (the CVEs behind the link, with severity, CVSS and a *Known ransomware use* flag from CISA KEV); **Graph** view shows the control at the hub with one node per category — tap a category to expand it (only one opens at a time), and tap any item for its details.

Updated 3. Try It → With your own Wazuh

Mentions root cause, and adds how to expose the Wazuh indexer for per-device CVEs.

> The Wazuh connector reads agents, SCA (configuration) results and — optionally, via the Wazuh indexer — per-device CVE findings. Because the API runs in the cloud, your Wazuh manager API (port 55000) must be reachable over public HTTPS; for a lab or home setup, a tunnel such as ngrok works. Private and LAN addresses are deliberately rejected. In your own tenant: **Connectors → Wazuh**, enter the manager URL and a Wazuh **API** user (e.g. `wazuh-wui`, not the dashboard `admin` login), save, and run. Each agent becomes an asset; Critical/High

CVEs reported for it become linked risks, so the device shows up in Blast Radius — with the specific CVEs listed as its root cause.

Per-device CVEs come from the Wazuh **indexer** (port 9200), which needs its own public HTTPS address (a second tunnel — e.g. a Cloudflare quick tunnel, since ngrok's free plan allows one endpoint) and must listen on more than `localhost` (`network.host` in `/etc/wazuh-indexer/opensearch.yml`). Enter its URL and the indexer user (e.g. `admin`) in the same connector form. Saving only updates the fields you fill in.

New 4. What's Actually Built → Graph Intelligence Engine

A new bullet, inserted before "Per-requirement framework coverage".

- **Root cause provenance** — every connector-created `Risk → Asset` link records the CVEs that caused it (`IMPACTS.driver_cves`). Blast Radius returns them per link, ransomware-flagged first and then by CVSS, so "this laptop is exposed to Ransomware Infection Risk" comes with *why*: e.g. two WinRAR CVEs CISA lists as used in ransomware campaigns — and therefore what to patch.

Updated 5. Universal Connector Architecture → connector table

Only the Wazuh row changes: indexer CVE detection is now live-verified.

Connector	Auth Pattern	Checks	Validation
Wazuh	HTTP Basic → session JWT (self-hosted SIEM/XDR)	2	Live-verified against a self-hosted manager and indexer: agent connectivity, SCA, and per-device CVE findings flowing through to Blast Radius root cause

Updated 6. Honest Limitations

Two new rows (Root cause, Connector scheduling). The Connector coverage row is reworded to drop the comparison with other tools.

Item	Status
Root cause	✅ Live — CVEs behind each connector-created risk link, with CISA KEV ransomware flag. Links created before this feature (or by hand) show "No CVE recorded" until the connector runs again. CISA KEV publishes no CVSS, so a KEV-only CVE shows severity alone until NVD or the scanner supplies a score.
Connector scheduling	⚠️ Connectors run on demand; no scheduled runs yet. Self-hosted tools behind a quick tunnel need the tunnel up (and its URL re-saved if it changed) for each run.
Connector coverage	⚠️ 7 connectors so far (Wazuh live-verified); more planned, and each new one is a single adapter file

Updated 7. Roadmap

Ticked: Wazuh indexer validation and root cause. Added: scheduled connector runs and a downloadable report.

> - ☑ Regulatory profile, personal-data flags and notification clocks in the Flutter UI
> - ☐ Real vendor credential testing (AWS free tier, Okta developer org, CrowdStrike/Qualys trial)
> - ☑ Wazuh connector live-data validation (agent connectivity + SCA)
> - ☑ Wazuh indexer vulnerability detection — live validation
> - ☑ Root cause (driving CVEs) for each exposed risk and asset
> - ☐ Scheduled connector runs
> - ☐ Downloadable compliance / blast-radius report (audit evidence)
> - ☐ CrowdStrike / Qualys connector live-data validation (pending real tenants)
> - ☐ In-app starter setup for newly registered tenants
> - ☑ CrowdStrike / Qualys connector adapters
> - ☑ Connector management UI in Flutter
> - ☑ Persistent encrypted connector credential storage
> - ☑ Graph visualization for blast radius (expandable hub-and-spoke view)
> - ☐ CIS Controls commercial licensing review (required before paid use)